

ISMS CONTEXT DOCUMENT

Tumaini Capital Ltd | ISO/IEC 27001:2022 | Clauses 4.1 & 4.2 | Prepared by: Head of Risk & Compliance | June 2026 | Fictional case study

This document fulfils the requirements of Clauses 4.1 and 4.2 of ISO/IEC 27001:2022. It provides a structured analysis of the external and internal context in which Tumaini Capital Ltd operates, and identifies the interested parties whose requirements are relevant to the Information Security Management System. The outputs of this analysis directly inform the ISMS scope (Clause 4.3), the information security risk assessment (Clause 6.1), and the setting of information security objectives (Clause 6.2).

CLAUSE 4.1 — UNDERSTANDING THE ORGANIZATION AND ITS CONTEXT

The following tables identify the external and internal issues that are relevant to Tumaini Capital's purpose and that affect the ISMS achieving its intended outcomes. Issues are assessed for significance (High / Medium / Low) to prioritize their treatment in the risk assessment.

4.1a — External Issues (PESTLE Analysis)

Category	Issue / Context	Information Security Implication	Significance
Political / Legal	Office of the Data Protection Commissioner (ODPC) increasing enforcement under the Data Protection Act, 2019	Mandatory data processing records, breach notification obligations, lawful basis requirements; non-compliance risks fines and reputational damage.	HIGH
Political / Legal	Central Bank of Kenya (CBK) oversight of digital lenders and mobile credit products	Regulatory expectations around customer data handling and platform security may expand; non-compliance could restrict licensing.	HIGH
Political / Legal	Computer Misuse and Cybercrimes Act, 2018	Legal liability for unauthorized access to or disclosure of customer data; relevant to incident response obligations.	MEDIUM
Economic	Growing Kenyan digital lending sector attracting increased regulatory scrutiny and cybercriminal targeting	Higher threat actor interest in fintech platforms holding financial and KYC data; increased probability of targeted attacks.	HIGH
Economic	Banking partner white-label deal contingent on ISO 27001 certification	Failure to certify within 12 months delays or loses a direct revenue stream; certification is a commercial prerequisite.	HIGH
Social / Market	Rising customer awareness of data privacy rights following ODPC communications campaigns	Borrower complaints or subject access requests may increase; CRM and data management controls must be able to respond promptly.	MEDIUM
Technology	Evolving threat landscape — phishing, credential theft, and social engineering targeting mobile-first financial services	Staff and customer-facing surfaces (USSD, app, email) are active attack vectors; awareness training and MFA controls are critical.	HIGH
Technology	Shared responsibility model in AWS cloud infrastructure (eu-west-1)	Physical/environmental security is AWS's responsibility; logical configuration, access control, and data encryption remain Tumaini's. Misconfiguration is the primary cloud risk.	HIGH
Technology	Third-party API dependencies (Safaricom M-Pesa, credit reference bureaus)	Outages or security incidents at third parties could affect availability or integrity of transactions; supplier risk management is required.	MEDIUM

Category	Issue / Context	Information Security Implication	Significance
Environmental	Power reliability in Kenya — dependency on grid stability for Kisumu office connectivity	Potential availability impact on systems accessed from Kisumu; business continuity and backup connectivity controls needed.	LOW

4.1b — Internal Issues

Category	Issue / Context	Information Security Implication	Significance
People	No dedicated information security role; responsibilities informally split between Head of Risk & Compliance and Head of Engineering	No single accountable owner for ISMS; risk of security tasks falling between departments. Addressed by formally appointing ISMS Lead.	HIGH
People	85 staff, mix of technical and non-technical; heavy reliance on BYOD phones for business communication	Human error and social engineering are realistic attack vectors; security awareness training and acceptable use controls are required.	MEDIUM
Process	Unresolved offboarding control gap — ex-employee CRM access not revoked promptly, resulting in unauthorized data export (8 months ago)	Formal, documented joiner/mover/leaver access control process with mandatory deactivation within 24 hours of exit is a priority control.	HIGH
Process	Security responsibilities and escalation paths not formally documented	Incident response and policy enforcement rely on informal norms; ISMS will formalize these through documented procedures and roles.	MEDIUM
Technology	Core platform hosted on AWS eu-west-1 (outside Kenya); data residency and latency considerations	ODPC's data localization guidance is evolving; data residency must be monitored. Current setup must be documented and risk-assessed.	MEDIUM
Technology	IT support partly outsourced to an external MSP (laptop provisioning, office network)	MSP has physical and logical access to company devices and network; supplier risk management and contractual controls are required.	MEDIUM
Governance	Flat organizational structure; no formal ISMS governance structure (steering committee, documented roles and responsibilities)	ISMS require defined governance: ISMS Lead, top management sponsor, departmental security champions. Structure must be established early.	HIGH
Governance	12-month certification timeline is tight given limited dedicated security headcount	Under-resourcing is an internal risk to the project itself; management commitment to releasing staff time is a dependency.	MEDIUM

Significance key: **HIGH** = requires direct ISMS control; **MEDIUM** = monitor and address in risk treatment; **LOW** = note and review periodically.

CLAUSE 4.2 — NEEDS AND EXPECTATIONS OF INTERESTED PARTIES

The following table identifies the parties relevant to Tumaini Capital's ISMS and their specific information security requirements. These requirements drive control selection, policy obligations, and monitoring mechanisms throughout the ISMS lifecycle.

Interested Party	Category	Information Security Requirements	Risk if Requirements Not Met	How Monitored / Addressed
Office of the Data Protection Commissioner (ODPC)	<i>Regulator</i>	Compliance with the Data Protection Act, 2019 Lawful basis for each processing activity Data breach notification within 72 hours Documented Records of Processing Activities (ROPA) Rights of data subjects (access, erasure, portability) upheld	Regulatory enforcement action, fines, reputational damage	Annual ROPA review; breach notification procedure; data subject request process
Central Bank of Kenya (CBK)	<i>Regulator</i>	Platform security controls for licensed digital lenders Customer financial data protection Operational resilience and availability	Licensing risk; regulatory direction	Monitor CBK circulars and digital credit guidelines; align controls with published requirements
Regional Bank Partner	<i>Commercial Partner</i>	Evidence of ISO/IEC 27001:2022 certification before data-sharing agreement is signed Documented security controls over shared customer data Incident notification obligations in the contract	Loss of white-label revenue deal; partnership stalls	Certification audit completion; contractual information security clauses in partnership agreement
Borrowers / Customers	<i>Customers</i>	Personal and financial data kept confidential KYC documents not shared without consent or legal basis Accurate credit reporting Prompt response to data subject access requests	Complaints to ODPC; reputational damage; churn	Access control over CRM; data minimization; subject access request procedure
Safaricom (M-Pesa API)	<i>Supplier / Third Party</i>	Secure API integration (TLS, authentication) Compliance with Safaricom API terms of use Incident notification for security events affecting the integration	Transaction integrity and availability risk	API security review; supplier risk register; SLA monitoring
Credit Reference Bureaus	<i>Supplier / Third Party</i>	Authorized and lawful data sharing only Accurate customer data transmitted Secure transmission (encrypted channels)	Data integrity risk; regulatory non-compliance if sharing is unauthorized	Data sharing agreements; access logs; data accuracy controls

Interested Party	Category	Information Security Requirements	Risk if Requirements Not Met	How Monitored / Addressed
Outsourced IT MSP	<i>Supplier</i>	Contractual confidentiality obligations Controlled physical and logical access to company assets Prompt incident escalation to Tumaini Capital	Insider threat; unauthorized access to devices and network	Supplier risk assessment; MSP contract review; access rights audit
Employees	<i>Internal</i>	Clear security policies and acceptable use guidelines Security awareness training Safe channel for reporting incidents without fear of blame	Policy non-compliance; human error	Annual awareness training; Acceptable Use Policy; incident reporting procedure
Board / Shareholders	<i>Internal / Governance</i>	Evidence that information security risk is managed Regulatory compliance maintained No material incidents that affect company value or reputation	Loss of investor confidence; governance failure	Management review outputs; ISMS dashboard; board-level incident reporting

This document is reviewed annually and following any material change to the business, regulatory environment, or ISMS scope. | Tumaini Capital Ltd — ISO/IEC 27001:2022 ISMS (fictional case study)